

CVEs más relevantes de la semana

Del 21/03/2026 al 28/03/2026

Porque el primer paso para defender es conocer las amenazas.



CVE-2019-25568

Descripción: Memu Play 6.0.7 contains an insecure file permissions vulnerability that allows low-privilege users to escalate privileges by replacing the MemuService.exe executable. Attackers can rename and overwrite MemuService.exe in the installation directory with a malicious executable, which executes with system-level privileges when the service restarts after a computer reboot.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-306

Tecnología: No especificado

Publicado el: 2026-03-21



CVE-2019-25614

Descripción: Free Float FTP 1.0 contains a buffer overflow vulnerability in the STOR command handler that allows remote attackers to execute arbitrary code by sending a crafted STOR request with an oversized payload. Attackers can authenticate with anonymous credentials and send a malicious STOR command containing 247 bytes of padding followed by a return address and shellcode to trigger code execution on t...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-22



CVE-2026-4567

Descripción: A vulnerability has been found in Tenda A15 15.13.07.13. The impacted element is the function UploadCfg of the file /cgi-bin/UploadCfg. The manipulation of the argument File leads to stack-based buffer overflow. The attack may be initiated remotely. The exploit has been disclosed to the public and may be used.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-119

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-4600

Descripción: Versions of the package jsrsasign before 11.1.1 are vulnerable to Improper Verification of Cryptographic Signature via the DSA domain-parameter validation in KJUR.crypto.DSA.setPublic (and the related DSA/X509 verification flow in src/dsa-2.0.js). An attacker can forge DSA signatures or X.509 certificates that X509.verifySignature() accepts by supplying malicious domain parameters such as $g=1$, ...

CVSS: 7.4 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-347

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-4601

Descripción: Versions of the package jsrsasign before 11.1.1 are vulnerable to Missing Cryptographic Step via the `KJUR.crypto.DSA.signWithMessageHash` process in the DSA signing implementation. An attacker can recover the private key by forcing `r` or `s` to be zero, so the library emits an invalid signature without retrying, and then solves for `x` from the resulting signature.

CVSS: 8.7 (HIGH)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-325

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-32968

Descripción: Due to the improper neutralisation of special elements used in an OS command, an unauthenticated remote attacker can exploit an RCE vulnerability in the com_mb24sysapi module, resulting in full system compromise. This vulnerability is a variant attack for CVE-2020-10383.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-78

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-4585

Descripción: A vulnerability has been found in Tiandy Easy7 Integrated Management Platform up to 7.17.0. This vulnerability affects unknown code of the file `/Easy7/apps/WebService/ImportSystemConfiguration.jsp` of the component Configuration Handler. The manipulation of the argument `File` leads to os command injection. The attack can be initiated remotely. The exploit has been disclosed to the public and may ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-77

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-33297

Descripción: WWBN AVideo is an open source video platform. Prior to version 26.0, the `setPassword.json.php` endpoint in the CustomizeUser plugin allows administrators to set a channel password for any user. Due to a logic error in how the submitted password value is processed, any password containing non-numeric characters is silently coerced to the integer zero before being stored. This means that regardl...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-30849

Descripción: Mantis Bug Tracker (MantisBT) is an open source issue tracker. Versions prior to 2.28.1 running on MySQL family databases are affected by an authentication bypass vulnerability in the SOAP API, as a result of an improper type checking on the password parameter. Other database backends are not affected, as they do not perform implicit type conversion from string to integer. Using a crafted SOAP ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-305

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-32913

Descripción: OpenClaw before 2026.3.7 contains an improper header validation vulnerability in fetchWithSsrFGuard that forwards custom authorization headers across cross-origin redirects. Attackers can trigger redirects to different origins to intercept sensitive headers like X-API-Key and Private-Token intended for the original destination.

CVSS: 9.3 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:L/A:N

Tipo: CWE-522

Tecnología: No especificado

Publicado el: 2026-03-23



CVE-2026-33195

Descripción: Active Storage allows users to attach cloud and local files in Rails applications. Prior to versions 8.1.2.1, 8.0.4.1, and 7.2.3.1, Active Storage's `DiskService#path_for` does not validate that the resolved filesystem path remains within the storage root directory. If a blob key containing path traversal sequences (e.g. `../`) is used, it could allow reading, writing, or deleting arbitrary fil...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33202

Descripción: Active Storage allows users to attach cloud and local files in Rails applications. Prior to versions 8.1.2.1, 8.0.4.1, and 7.2.3.1, Active Storage's `DiskService#delete\_prefixed` passes blob keys directly to `Dir.glob` without escaping glob metacharacters. If a blob key contains attacker-controlled input or custom-generated keys with glob metacharacters, it may be possible to delete unintended ...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-74

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33211

Descripción: Tekton Pipelines project provides k8s-style resources for declaring CI/CD-style pipelines. Starting in version 1.0.0 and prior to versions 1.0.1, 1.3.3, 1.6.1, 1.9.2, and 1.10.2, the Tekton Pipelines git resolver is vulnerable to path traversal via the `pathInRepo` parameter. A tenant with permission to create `ResolutionRequests` (e.g. by creating `TaskRuns` or `PipelineRuns` that use the git ...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:N

Tipo: CWE-22

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4001

Descripción: The Woocommerce Custom Product Addons Pro plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 5.4.1 via the custom pricing formula `eval()` in the `process_custom_formula()` function within `includes/process/price.php`. This is due to insufficient sanitization and validation of user-submitted field values before passing them to PHP's `eval()` function. The ...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-95

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4283

Descripción: The WP DSGVO Tools (GDPR) plugin for WordPress is vulnerable to unauthorized account destruction in all versions up to, and including, 3.1.38. This is due to the `super-unsubscribe` AJAX action accepting a `process\_now` parameter from unauthenticated users, which bypasses the intended email-confirmation flow and immediately triggers irreversible account anonymization. This makes it possible for...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:N/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33854

Descripción: Out-of-bounds Write vulnerability in MolotovCherry Android-ImageMagick7. This issue affects Android-ImageMagick7: before 7.1.2-10.

CVSS: 8.8 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2019-25628

Descripción: Download Accelerator Plus DAP 10.0.6.0 contains a structured exception handler buffer overflow vulnerability that allows remote attackers to execute arbitrary code by crafting malicious URLs. Attackers can create specially crafted URLs with overflowing buffer data that overwrites SEH pointers and executes embedded shellcode when imported through the application's web page import functionality.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2019-25646

Descripción: Tabs Mail Carrier 2.5.1 contains a buffer overflow vulnerability in the MAIL FROM SMTP command that allows remote attackers to execute arbitrary code by sending a crafted MAIL FROM parameter. Attackers can connect to the SMTP service on port 25 and send a malicious MAIL FROM command with an oversized buffer to overwrite the EIP register and execute a bind shell payload.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4688

Descripción: Sandbox escape due to use-after-free in the Disability Access APIs component. This vulnerability affects Firefox < 149, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4689

Descripción: Sandbox escape due to incorrect boundary conditions, integer overflow in the XPCOM component. This vulnerability affects Firefox < 149, Firefox ESR < 115.34, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-190

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4691

Descripción: Use-after-free in the CSS Parsing and Computation component. This vulnerability affects Firefox < 149, Firefox ESR < 115.34, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4692

Descripción: Sandbox escape in the Responsive Design Mode component. This vulnerability affects Firefox < 149, Firefox ESR < 115.34, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4696

Descripción: Use-after-free in the Layout: Text and Fonts component. This vulnerability affects Firefox < 149, Firefox ESR < 115.34, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4698

Descripción: JIT miscompilation in the JavaScript Engine: JIT component. This vulnerability affects Firefox < 149, Firefox ESR < 115.34, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-843

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4700

Descripción: Mitigation bypass in the Networking: HTTP component.
This vulnerability affects Firefox < 149, Firefox ESR < 140.9,
Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4701

Descripción: Use-after-free in the JavaScript Engine component.
This vulnerability affects Firefox < 149, Firefox ESR < 140.9,
Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4702

Descripción: JIT miscompilation in the JavaScript Engine component. This vulnerability affects Firefox < 149, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-843

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4705

Descripción: Undefined behavior in the WebRTC: Signaling component. This vulnerability affects Firefox < 149, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4710

Descripción: Incorrect boundary conditions in the Audio/Video component. This vulnerability affects Firefox < 149, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4711

Descripción: Use-after-free in the Widget: Cocoa component. This vulnerability affects Firefox < 149, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4715

Descripción: Uninitialized memory in the Graphics: Canvas2D component. This vulnerability affects Firefox < 149, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-908

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4716

Descripción: Incorrect boundary conditions, uninitialized memory in the JavaScript Engine component. This vulnerability affects Firefox < 149, Firefox ESR < 140.9, Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-908

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4717

Descripción: Privilege escalation in the Netmonitor component.

This vulnerability affects Firefox < 149, Firefox ESR < 140.9,

Thunderbird < 149, and Thunderbird < 140.9.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: NVD-CWE-noinfo

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4723

Descripción: Use-after-free in the JavaScript Engine component.
This vulnerability affects Firefox < 149 and Thunderbird < 149.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4724

Descripción: Undefined behavior in the Audio/Video component. This vulnerability affects Firefox < 149 and Thunderbird < 149.

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-758

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-4725

Descripción: Sandbox escape due to use-after-free in the Graphics: Canvas2D component. This vulnerability affects Firefox < 149 and Thunderbird < 149.

CVSS: 10.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:C/C:H/I:H/A:H

Tipo: CWE-416

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33334

Descripción: Vikunja is an open-source self-hosted task management platform. Starting in version 0.21.0 and prior to version 2.2.0, the Vikunja Desktop Electron wrapper enables `nodeIntegration` in the renderer process without `contextIsolation` or `sandbox`. This means any cross-site scripting (XSS) vulnerability in the Vikunja web frontend -- present or future -- automatically escalates to full remote cod...

CVSS: 9.6 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-94

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33407

Descripción: Wallos is an open-source, self-hostable personal subscription tracker. Prior to version 4.7.0, Wallos endpoints/logos/search.php accepts HTTP_PROXY and HTTPS_PROXY environment variables without validation, enabling SSRF via proxy hijacking. The server performs DNS resolution on user-supplied search terms, which can be controlled by attackers to trigger outbound requests to arbitrary domains. Th...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:N/A:H

Tipo: CWE-918

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33409

Descripción: Parse Server is an open source backend that can be deployed to any infrastructure that can run Node.js. Prior to versions 8.6.52 and 9.6.0-alpha.41, an authentication bypass vulnerability allows an attacker to log in as any user who has linked a third-party authentication provider, without knowing the user's credentials. The attacker only needs to know the user's provider ID to gain full access...

CVSS: 9.1 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N

Tipo: CWE-287

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33768

Descripción: Astro is a web framework. Prior to version 10.0.2, the @astrojs/vercel serverless entrypoint reads the x-astro-path header and x_astro_path query parameter to rewrite the internal request path, with no authentication whatsoever. On deployments without Edge Middleware, this lets anyone bypass Vercel's platform-level path restrictions entirely. The override preserves the original HTTP method and ...

CVSS: 6.5 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:L/A:N

Tipo: CWE-441

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2026-33511

Descripción: pyLoad is a free and open-source download manager written in Python. From version 0.4.20 to before version 0.5.0b3.dev97, the local_check decorator in pyLoad's ClickNLoad feature can be bypassed by any remote attacker through HTTP Host header spoofing. This allows unauthenticated remote users to access localhost-restricted endpoints, enabling them to inject arbitrary downloads, write files to t...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-639

Tecnología: No especificado

Publicado el: 2026-03-24



CVE-2025-59706

Descripción: In N2W before 4.3.2 and 4.4.0 before 4.4.1, improper validation of API request parameters enables remote code execution.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2025-59707

Descripción: In N2W before 4.3.2 and 4.4.x before 4.4.1, there is potential remote code execution and account credentials theft because of a spoofing vulnerability.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-290

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2026-33749

Descripción: n8n is an open source workflow automation platform. Prior to versions 1.123.27, 2.13.3, and 2.14.1, an authenticated user with permission to create or modify workflows could craft a workflow that produces an HTML binary data object without a filename. The `/rest/binary-data` endpoint served such responses inline on the n8n origin without `Content-Disposition` or `Content-Security-Policy` header...

CVSS: 9.0 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:C/C:H/I:H/A:H

Tipo: CWE-79

Tecnología: No especificado

Publicado el: 2026-03-25



CVE-2026-33942

Descripción: Saloon is a PHP library that gives users tools to build API integrations and SDKs. Versions prior to 4.0.0 used PHP's unserialize() in AccessTokenAuthenticator::unserialize() to restore OAuth token state from cache or storage, with allowed_classes => true. An attacker who can control the serialized string (e.g. by overwriting a cached token file or via another injection) can supply a serialized...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-502

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2026-4484

Descripción: The Masteriyo LMS plugin for WordPress is vulnerable to Privilege Escalation in all versions up to, and including, 2.1.6. This is due to the plugin allowing a user to update the user role through the 'InstructorsController::prepare_object_for_database' function. This makes it possible for authenticated attackers, with Student-level access and above, to elevate their privileges to that of an adm...

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-862

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25183

Descripción: Shipping System CMS 1.0 contains an SQL injection vulnerability that allows unauthenticated attackers to bypass authentication by injecting SQL code through the username parameter. Attackers can submit malicious SQL payloads using boolean-based blind techniques in POST requests to the admin login endpoint to authenticate without valid credentials.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25185

Descripción: Wecodex Restaurant CMS 1.0 contains an SQL injection vulnerability that allows unauthenticated attackers to manipulate database queries by injecting SQL code through the username parameter. Attackers can send POST requests to the login endpoint with malicious SQL payloads using boolean-based blind or time-based blind techniques to extract sensitive database information.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25195

Descripción: Wecodex Hotel CMS 1.0 contains an SQL injection vulnerability in the admin login functionality that allows unauthenticated attackers to bypass authentication by injecting SQL code. Attackers can submit malicious SQL payloads through the username parameter in POST requests to index.php with action=processlogin to extract sensitive database information or gain unauthorized administrative access.

CVSS: 8.2 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2018-25201

Descripción: School Management System CMS 1.0 contains an SQL injection vulnerability in the admin login functionality that allows attackers to bypass authentication by injecting SQL code through the username parameter. Attackers can submit malicious payloads using boolean-based blind SQL injection techniques to the processlogin endpoint to authenticate as administrator without valid credentials.

CVSS: 7.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:N

Tipo: CWE-89

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2025-55267

Descripción: HCL Aftermarket DPC is affected by Unrestricted File Upload vulnerability, allows attacker to upload and execute malicious scripts, gaining full control over the server.

CVSS: 5.7 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:N/I:H/A:N

Tipo: CWE-434

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2025-55269

Descripción: HCL Aftermarket DPC is affected by Weak Password Policy vulnerability, which makes it easier for attackers to guess weak passwords or use brute-force techniques to gain unauthorized access to user accounts.

CVSS: 4.2 (MEDIUM)

Vector: CVSS:3.1/AV:N/AC:H/PR:N/UI:R/S:U/C:L/I:N/A:L

Tipo: CWE-521

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2025-55270

Descripción: HCL Aftermarket DPC is affected by Improper Input Validation which allows an attacker to inject executable code and can carry out attacks such as XSS, SQL Injection, Command Injection etc.

CVSS: 3.5 (LOW)

Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:R/S:U/C:L/I:N/A:N

Tipo: CWE-20

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2025-55261

Descripción: HCL Aftermarket DPC is affected by Missing Functional Level Access Control which will allow attacker to escalate his privileges and may compromise the application and may steal and manipulate the data.

CVSS: 8.1 (HIGH)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:R/S:U/C:H/I:N/A:H

Tipo: CWE-284

Tecnología: No especificado

Publicado el: 2026-03-26



CVE-2016-20049

Descripción: JAD 1.5.8e-1kali1 and prior contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by supplying oversized input that exceeds buffer boundaries. Attackers can craft malicious input strings exceeding 8150 bytes to overflow the stack, overwrite return addresses, and execute shellcode in the application context.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2017-20225

Descripción: TiEmu 2.08 and prior contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by exploiting inadequate boundary checks on user-supplied input. Attackers can trigger the overflow through command-line arguments passed to the application, leveraging ROP gadgets to bypass protections and execute shellcode in the application context.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2017-20227

Descripción: JAD Java Decompiler 1.5.8e-1kali1 and prior contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by supplying overly long input that exceeds buffer boundaries. Attackers can craft malicious input passed to the jad command to overflow the stack and execute a return-oriented programming chain that spawns a shell.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2017-20229

Descripción: MAWK 1.3.3-17 and prior contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by exploiting inadequate boundary checks on user-supplied input. Attackers can craft malicious input that overflows the stack buffer and execute a return-oriented programming chain to spawn a shell with application privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2018-25220

Descripción: Bochs 2.6-5 contains a stack-based buffer overflow vulnerability that allows attackers to execute arbitrary code by supplying an oversized input string to the application. Attackers can craft a malicious payload with 1200 bytes of padding followed by a return-oriented programming chain to overwrite the instruction pointer and execute shell commands with application privileges.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2018-25221

Descripción: EChat Server 3.1 contains a buffer overflow vulnerability in the chat.ghp endpoint that allows remote attackers to execute arbitrary code by supplying an oversized username parameter. Attackers can send a GET request to chat.ghp with a malicious username value containing shellcode and ROP gadgets to achieve code execution in the application context.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



CVE-2018-25223

Descripción: Crashmail 1.6 contains a stack-based buffer overflow vulnerability that allows remote attackers to execute arbitrary code by sending malicious input to the application. Attackers can craft payloads with ROP chains to achieve code execution in the application context, with failed attempts potentially causing denial of service.

CVSS: 9.8 (CRITICAL)

Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

Tipo: CWE-787

Tecnología: No especificado

Publicado el: 2026-03-28



Resumen del Reporte

CVEs analizados: 61

Promedio CVSS: 9.15

Fuente: nvd.nist.gov

Nos vemos la próxima semana. Hack the Cat 🐱

